INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

DESIGN A SECURITY AWARENESS PROGRAM

GRC 206: Design a Security Awareness Program

Student Name: JOY ORILADE

Student ID: 2025/GCR/2512719

Email Address: gcr2512719@students.icdfa.edu.ng

Date: 11th November 2026

Instructor: Com Idris Aminu

A practical, indicidual assignment

Design a realistic program for Northbridge Logistics using the five-stage lifecycle: assess, plan, deliver, measure, and improve.

Task 1: Assess

1.1. List the top three human-driven risks and justify each using the scenario

1. Invoice fraud via phishing or business email compromise (BEC) Recent invoice-fraud attempts show that attackers are targeting payment processes. Staff who approve or process invoices may fall for spoofed emails requesting changes to bank details. This risk is high because it directly leads to financial loss and is driven by human action (clicking, responding, or failing to verify).

2. Password reuse and weak credential hygiene Two staff reused passwords after a breach. This indicates incomplete password hygiene and likely limited multi-factor authentication (MFA) adoption. Compromised credentials can give attackers access to email, ERP systems, and customer data, amplifying other risks.

3. Mishandling of regulated customer data on mobile or shared devices The company handles regulated customer data across warehouses and remote sales. Staff may store data on personal devices, use public Wi-Fi without protection, or leave shared warehouse terminals unlocked. This creates privacy, compliance, and data-loss risks.

1.2. Segment at least four audience and describe each audience's needs.

Audience	Approx. group / exposure	Distinct learning needs and topics
Head-office staff (including Finance, Procurement, HR and customer support)	Assumption: 250; email-heavy work, supplier/customer records and payment workflows.	Invoice red flags; supplier bank-detail change verification; business email compromise; secure data sharing; privacy and clean-desk habits. Finance/Procurement receive deeper payment-control practice.
Warehouse and operations staff	Assumption: 400; shift-based work, shared spaces/devices and physical paperwork.	Short shift briefings; badge/tailgating awareness; device and paper security; suspicious QR codes/messages; safe reporting to a supervisor or service desk.

Remote sales staff	Assumption: 120; mobile devices, travel, customer contact and remote networks.	Mobile phishing/smishing; secure Wi-Fi and screen privacy; customer-data handling; identity verification; secure use of approved collaboration tools.
Managers, executives and privileged/IT users	Assumption: 30; approvals, sensitive access and ability to influence controls.	Payment approval and escalation; targeted impersonation; access and MFA hygiene; incident leadership; role-modelling and prompt reporting. IT receives focused account-compromise response practice.

The headcount split is an illustrative planning assumption only; HR must replace it with the actual staff list and role mapping before launch. Employees may belong to more than one learning group.

1.3. Propose a baseline to capture before launch, including where the evidence would come from.

During Month 1, the security lead and HR should capture a baseline before campaign messages or simulations begin. Use the previous 6–12 months of incident records where available, and run a short anonymous knowledge check plus a controlled initial phishing simulation. Record the measurement date, population, exclusions and data limitations.

- Incident baseline: number and type of confirmed invoice-fraud attempts, credential incidents, data-handling incidents and near misses; source: incident register, Finance fraud log and service desk.
- Phishing baseline: click rate, credential-submission rate if safely simulated, and reporting rate; source: approved simulation platform or manually tracked test messages.
- Reporting baseline: median time from receipt/suspicion to report and proportion of staff who know the reporting route; source: ticket timestamps and a short staff survey.
- Learning baseline: role-based knowledge-check scores and completion records; source: short quiz, attendance sheet or existing learning platform.

Where historical records are incomplete, mark the baseline as incomplete and use Month 1 as the first comparable measurement. Do not infer that no incidents occurred simply because none were recorded.

Task 2: Plan

2.1 Measurable programme objectives

Objective (proposed target)	Evidence and deadline	Accountable owner
O1 – By Month 12, reduce the phishing simulation click rate by at least 40% relative to the Month 1 baseline, and increase the report rate by at least 30 percentage points or to at least 60%, whichever is the more practical target after baseline review.	Quarterly simulations using comparable difficulty and audience; report baseline and Month 12 results with denominator and exclusions.	Security Awareness Lead; department managers support participation.
O2 – By Month 12, achieve at least 95% completion of core awareness learning and at least 90% of staff correctly answer role-relevant questions on invoice verification, credential safety and data handling.	Monthly completion register; short scenario-based knowledge checks at launch, Month 6 and Month 12.	HR Learning/Training Lead; managers follow up non-completion.
O3 – By Month 12, reduce confirmed human-related invoice-fraud, credential-compromise and avoidable data-handling incidents by 25% against the prior 6–12-month baseline, adjusted for reporting changes and business volume where possible.	Incident register and Finance/service-desk records reviewed quarterly; distinguish confirmed incidents from attempts and near misses.	Risk/Security Lead with Finance and IT owners.

These are proposed targets, not Northbridge performance results. O1's percentage-point target should be finalised after the Month 1 baseline so that it remains meaningful and achievable.

2.2 Governance and ownership

- Executive sponsor – Chief Operating Officer (proposed): approves the programme, protects staff time, reinforces expectations and resolves resource barriers.
- Programme owner – Security Lead (proposed): maintains the risk-to-learning plan, materials, simulations, metrics, incident themes and quarterly review actions.

- HR/Learning Lead: maintains the staff and role list, onboarding triggers, completion records, accessibility and shift-friendly scheduling.
- IT/Service Desk Lead: confirms technical guidance, operates the reporting channel, triages suspicious messages and supplies account/security incident data.
- Finance/Procurement Lead: validates invoice and supplier-change procedures, provides realistic fraud scenarios and reviews payment-related near misses.
- Department managers / warehouse supervisors: deliver short toolbox talks, release staff to learn, encourage reporting and escalate operational barriers.

A small programme working group can meet quarterly rather than creating a new committee. Each owner should have a named deputy to maintain continuity.

2.3 Role-based learning pathway

All staff receive a short core module covering social engineering, unique passwords and MFA where available, customer-data handling, device/physical security and how to report. Additional modules are assigned according to role and access. This is more proportionate than giving all 800 employees lengthy specialist training.

Task 3: Deliver

3.1 Formats matched to the workforce

- Head office: 10–15 minute monthly microlearning or team huddles, short email examples and Finance/Procurement tabletop exercises using a fake supplier bank-detail change.
- Warehouses: 5–10 minute supervisor-led toolbox talks at shift start, laminated visual reminders at clock-in areas and brief scenario discussions. Repeat each topic across shifts; do not rely on email-only delivery.
- Remote sales: mobile-friendly microlearning, short virtual team sessions and examples involving fake customer enquiries, delivery updates, QR codes, SMS and public Wi-Fi.
- Managers and privileged users: quarterly 20–30 minute decision exercises covering urgent executive requests, MFA fatigue, access responsibility and incident escalation.
- All staff: monthly short awareness prompt; quarterly phishing simulation; new-starter training; annual refresher and role-specific follow-up where needed.

3.2 Onboarding and phishing simulations

New employees should complete the core module and acknowledge the reporting route within their first 10 working days. Managers confirm completion; HR tracks overdue learning and provides a make-up opportunity. Contractors with access should receive equivalent instructions before access is granted, subject to contract and access arrangements.

Run a controlled simulation in Months 3, 6, 9 and 12. Begin with a low-risk, clearly authorised test; avoid collecting real passwords or exposing staff to harmful content. Use scenarios relevant to Northbridge, such as an invoice attachment, a delivery exception, a password reset or a supplier bank-detail change. Measure clicks and reports, not individual embarrassment. Anyone who interacts with a simulation receives immediate, private coaching that explains the warning signs and correct action. Repeat learning for patterns of risk rather than publicly naming individuals.

3.3 No-blame reporting and response

Provide one simple route: a dedicated security-report mailbox or the existing service-desk ticket category, with a phone/supervisor escalation option for warehouse employees. Publish the route on posters, induction material and the intranet. Staff should report suspicious messages without forwarding them to colleagues, clicking links or replying. If a person has clicked, entered credentials,

approved an unexpected MFA prompt or sent information to the wrong recipient, they should report immediately and state what happened. The service desk acknowledges and triages the report, alerts IT/Security, and follows the incident process. Reporting a mistake promptly is treated as responsible behaviour; deliberate misconduct is handled through existing HR processes, not through the awareness campaign.

CISA advises staff to report suspicious communications and to be cautious of urgent requests, links and requests for personal information [2]. The programme should teach a consistent local reporting path rather than expecting employees to investigate threats themselves.

Task 4: Measure

Four metrics covering reach, behaviour, and outcomes. All compared against the pre-launch baseline. A change is interpreted as follows: rising reach shows program delivery; rising reporting and MFA show safer actions; falling successful fraud attempts shows outcome improvement.

Metric and calculation	Data source	Owner / frequency	What change means
Core learning completion = staff completing required module ÷ staff assigned × 100.	HR/LMS or signed team register; segmented by site, shift and role.	HR Lead; monthly.	Shows reach only. Low completion indicates access, scheduling or manager follow-up issues.
Phishing click rate = unique simulation clickers ÷ delivered simulation messages × 100. Report rate = unique reporters ÷ delivered messages × 100.	Simulation logs and security mailbox/ticket records; deduplicate where possible.	Security Lead; each quarter.	Falling clicks and rising reports suggest safer recognition and action. Compare similar simulations.
Time to report = median time between message delivery/receipt and first report; also track percentage reported within 30 minutes.	Email timestamps, service desk and simulation logs.	Service Desk Lead; monthly/quarterly.	Shorter time supports faster containment. Missing timestamps limit confidence.
Role-scenario accuracy = correct answers ÷ total questions answered × 100, reported by role.	Three-to-five question scenario checks at baseline, Month 6 and Month 12.	HR and Security; twice yearly.	Improvement indicates better understanding; high scores should be checked against behaviour.
Human-related incident rate = confirmed incidents in the three priority categories per 100 employees; compare with prior baseline and note volume/exposure.	Incident register, Finance fraud log, IT tickets and privacy records.	Security, Finance and IT; quarterly.	A sustained reduction suggests risk reduction. Better reporting can initially increase recorded cases.

Leadership Reporting

4.1 Leadership reporting

The Security Lead provides a one-page quarterly dashboard to the COO and working group. It should show baseline, current result, target, trend, audience/site breakdown, incidents and near misses, learner feedback, data limitations and three actions requiring a decision. Report aggregated results; restrict identifiable incident details to authorised responders. Explain changes in workforce size, simulation difficulty or reporting tools before comparing periods. Leadership decisions may include extra supervisor time, revised payment controls, additional coaching for a role, or a change to the reporting channel.

Task 5 – Improve and sustain

5.1 Quarterly review cycle

At the end of Months 3, 6, 9 and 12, the COO sponsor (or delegate), Security Lead, HR, IT/Service Desk, Finance/Procurement and rotating department representatives review the dashboard, incident themes, simulation results, completion gaps and feedback. The Security Lead records each decision in

an action log with an owner, due date, status and evidence of closure. The Month 12 review sets priorities and targets for the next annual cycle.

5.2 Triggers for updates and learner feedback

- Update content promptly after an invoice-fraud attempt, credential incident, customer-data exposure, new scam pattern, major system/process change or change in legal/contractual obligations.
- Collect feedback through a two-question pulse survey after each quarterly topic, brief manager check-ins and rotating warehouse shift discussions. Offer an anonymous option and ask whether the example was relevant, the instructions were clear and the reporting route was accessible.
- Review feedback by role and work location. If warehouse staff cannot access email training, move the activity to shift briefings; if remote staff report mobile scams, add smishing and QR-code examples; if Finance identifies supplier verification delays, work with process owners to make the safe route usable.

5.3 Positive recognition

- Recognise a monthly or quarterly "Security Champion" team or individual for prompt reporting, helpful peer guidance or identifying a process weakness. Obtain consent before naming anyone.
- Share anonymised "good catch" examples in team briefings, explaining what was noticed and what action prevented harm. Never publish simulation clickers or use public rankings.

Recognition should reward reporting and safe decisions, including early reporting after a mistake. It should not reward low report counts, because that could discourage staff from raising concerns.

References

[1] Merritt, M. et al. (2024). Building a Cybersecurity and Privacy Learning Program (NIST Special Publication 800-50 Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-50r1

[2] Cybersecurity and Infrastructure Security Agency (CISA). (2024). Phishing: General Security Tips. https://www.cisa.gov/sites/default/files/2024-02/Update%20to%20Phishing%20General%20Security%20Postcard_01.01.2024.pdf

[3] National Institute of Standards and Technology (NIST). (2026). Phishing – Small Business Cybersecurity. https://www.nist.gov/itl/smallbusinesscyber/guidance-topic/phishing

The scenario facts and task requirements are taken from the GRC206 assignment handout. External references support the programme design; Northbridge-specific staffing, controls and results are not asserted as facts.

12-Month Security Awareness Programme Calendar

Proposed sequence: Month 1 is the baseline and launch month. Activities are deliberately short and use existing channels. Monthly themes apply to all staff unless a role-specific audience is stated.

Month	Activity / theme	Audience	Owner	Measurement point
1	Launch; baseline survey, knowledge check and initial phishing test; publish reporting route.	All staff; managers	Security + HR; IT	Baseline: knowledge, clicks/reports, incident history
2	Core security: suspicious messages, links, attachments and reporting practice.	All staff; shift briefings for warehouse	Security + supervisors	Completion; report-route awareness
3	Invoice fraud and supplier bank-detail verification tabletop; phishing simulation 1; Q1 review.	Finance, Procurement, managers; all staff simulation	Finance + Security	Click/report rate; Q1 actions

4	Unique passwords, password manager/MFA guidance (where available), account compromise response.	All staff; deeper session for IT/admins	IT + Security	Scenario accuracy; credential incident trend
5	Customer data handling, correct recipients, approved storage and clean desk/screen habits.	Head office, sales, warehouse	Privacy/Compliance + managers	Spot-check themes; feedback
6	Remote/mobile security, smishing and QR-code risks; simulation 2; Q2 review.	Remote sales; all staff simulation	Security + Sales managers	Click/report rate; knowledge pulse; Q2 actions
7	Physical security: badges, visitors, tailgating, unattended devices and printed records.	Warehouse and head office	Operations + supervisors	Toolbox talk reach; reported physical concerns
8	Safe collaboration and file sharing; verify identity before disclosing customer information.	All staff; customer-facing roles focus	IT + Customer Operations	Scenario accuracy; data-handling near misses
9	Urgent executive/supplier impersonation exercise; simulation 3; Q3 review.	Managers, Finance, Procurement; all staff simulation	Security + Finance	Simulation results; Q3 actions
10	Incident response for employees: what to report, what details to preserve, who to contact.	All staff; service desk and supervisors	IT/Service Desk + Security	Time to report; report quality
11	Role refresh based on incident trends; targeted make-up coaching for groups below target.	Priority roles/sites from dashboard	Security + HR + managers	Targeted completion and accuracy
12	Annual refresher and final simulation; measure against baseline; Q4/annual review and next-year plan.	All staff; leadership review	Security + HR; COO sponsor	Final objectives, incident trend, improvement plan

Quarterly governance checkpoints: Month 3, Month 6, Month 9 and Month 12. Each review examines reach, behaviour, incidents, feedback and overdue actions. Managers repeat warehouse sessions across shifts and provide make-up opportunities.

Resource note: The plan assumes one security lead coordinates content and metrics, while HR, IT, Finance and supervisors contribute short activities as part of existing responsibilities. If resources tighten, preserve onboarding, the reporting route, invoice-fraud guidance and quarterly measurement before adding new campaign materials.

Short Reflection (approximately 150 words)

The hardest part of designing this programme was balancing the different ways 800 employees work with the limited time and resources available to a small security team. A single online course would be easy to administer, but it would not reliably reach warehouse employees working shifts or address the mobile and customer-facing risks of remote sales staff. I therefore selected short, repeated learning activities and supervisor-led discussions, supported by a small number of quarterly simulations. Another challenge was setting targets without any actual Northbridge baseline. I treated the targets as proposals and included a Month 1 measurement period rather than presenting invented figures as current performance. I also avoided relying on attendance as proof of success. Reporting behaviour, simulation results, incident trends and role-based knowledge checks provide a more useful picture, although incident numbers may initially rise when employees become more willing to report. The programme therefore combines measurement with quarterly review and feedback.